SECURITY SYNC · WEEKLY CYBERSECURITY SESSION

The Controls Nobody Talks About Until They Fail

A Practical Guide to ITGC

Dr. Ponnaluru Sowjanya

ABOUT THE SPEAKER

Dr. Ponnaluru Sowjanya

Views expressed here are my own.

ROLE

AVP (IS Audit), State Bank of India: IT governance, ITGC and continuous audit

COMMUNITY

Membership Director, ISACA Hyderabad Chapter

CREDENTIALS

PhD · CISA · AIGP · ISO/IEC 27001 and ISO/IEC 42001 Lead Auditor

A SIMPLE IDEA

Small things ignored, big things lost



A tiny leak





A ruined home



A skipped oil check





A broken engine



One unlocked door





Everything stolen

Companies are no different.

REAL COMPANIES

How much did they lose?

2012

Knight Capital

$460M

lost in 45 minutes

2017

Equifax

$575M+

settlement, at least

2018

TSB Bank

£48.65M

in regulator fines

2024

CrowdStrike

$5.4B

estimated loss, big US companies

Different measures: a loss, a settlement, fines and an estimate. Not directly comparable.

NOW THE REASONS

What went wrong? Simple mistakes



8 computers, 1 missed

Knight Capital

- 1 of 8 computers missed the update
- Nobody double-checked



Equifax

- Security warning ignored
- Fix still missing in July



Deadline first

TSB Bank

- Rushed to a deadline
- Testing cut back
- Weak backup plan



Fault not found

CrowdStrike

- Hidden fault slipped past testing
- Crashed 8.5M Windows PCs

Reasons as stated in public findings: SEC, FTC, FCA and PRA, CrowdStrike, Microsoft

NOW THE TOPIC

The plan from here

9–15 min	What ITGC means, and its four domains
15–25 min	The domains in practice: access, change, operations
25–30 min	Interactive: spot the failure
30–43 min	How ITGC is tested, where it shows up, ITGC in the AI era
43–52 min	Your turn: fix the four failures
52–60 min	Questions and discussion

THE TOPIC

What does ITGC stand for?

IT
Information Technology: computers, networks, software

+

General
Rules for all systems, not just one app

+

Controls
Checks that keep systems safe and reliable

ITGC = IT General Controls

IN SIMPLE WORDS

The safety rules under every system

What people see: banking app, payroll, student portal

ITGC: the foundation underneath

Who can enter?

Who can change it?

Does it keep running?

If the foundation cracks, everything above it becomes doubtful.

FOUNDATIONS

The four ITGC domains

Access to programs and data

Who can get in, and what can they do?

Program change management

Is every change approved, tested and traceable?

Program development

Are new systems built, tested and signed off properly?

Computer operations

Do backups, jobs and incident handling run reliably?

Today in depth: access, change and operations. Development is covered inside change.

DOMAIN 1 OF 3

Access: who can enter?

Joiner

Gets only the access the job needs

Mover

Access changes with the new role

Leaver

Access closed on the last day

Every few months, someone checks the list. Really checks it.

Audit question: whose access should have ended, but did not?

DOMAIN 2 OF 3

Program change management

Step 1
Request
Business reason and risk are recorded

Step 2
Approve
The right people sign off before work starts

Step 3
Test
Tested outside production, with evidence

Step 4
Deploy
Only approved changes reach production

Step 5
Verify
Results checked, rollback ready

Segregation of duties: the person who writes a change should not be the one who pushes it to production.

DOMAIN 3 OF 3

Operations: does it keep running?

Backups
Taken daily, and restored in tests

Scheduled jobs
Nightly jobs run, failures are noticed

Incidents
Problems are logged and fixed at the root

Monitoring
Alerts reach someone who acts

A backup you have never restored is a hope, not a control.

INTERACTIVE · ANSWER IN THE CHAT

Which control failed?

A

A developer fixes a bug directly on the live system on a Friday evening. No ticket, no approval.

B

A finance clerk moved to HR last year. They can still approve payments.

C

The nightly backup has failed for three weeks. Nobody noticed.

Type the letter and the domain in the chat: access, change or operations?

THE ANSWERS

What should have caught each one

A Change

An emergency change process, with approval and review afterwards

B Access

A mover process, and a real review of who has access

C Operations

Backup alerts, and regular restore tests

The pattern: each failure is small, silent and fixable if someone is looking.

HOW ITGC IS TESTED

How auditors test a control

DESIGN

Is the control built to address the risk?

OPERATING EFFECTIVENESS

Did it work, consistently, across the whole period?

FOUR WAYS TO GATHER EVIDENCE

Inquiry

Ask the control owner how it works

Observation

Watch the control being performed

Inspection

Examine evidence: tickets, logs, approvals

Re-performance

Redo the control yourself and compare results

Inquiry alone is never enough.

WORKED EXAMPLE

Testing leaver access in four steps

1. **Get the population**
   The HR list of everyone who left during the period

2. **Select a sample**
   Use a risk-based or statistical method

3. **Compare the dates**
   Exit date against the date each account was disabled

4. **Conclude**
   Any account still active after exit is an exception

THEN ASK

Was the account used after the exit date? That turns a control gap into a potential incident.

KEEP AS EVIDENCE

The HR list, system extracts, your sample selection and the comparison.

REAL-WORLD RESULTS

What the market data says

$4.44M

global average cost of a data breach, 2025

INR 220M

India average, an all-time high

263 days

India average to find and contain a breach

> Unfixed flaws and weak vendor control are behind many breaches. Both are ITGC topics.

Source: IBM and Ponemon, Cost of a Data Breach Report 2025

BEYOND THE BASICS

Where ITGC shows up

SOX (Section 404)

ITGC support the reliability of internal control over financial reporting.

ISO/IEC 27001:2022

Annex A controls cover access, change, backup, logging and more.

COBIT

Governance and management objectives for enterprise IT.

Sector regulators

Bodies such as RBI for Indian banks expect the same basics.

Different names, same core: who can access, how change happens, whether systems run.

ITGC IN THE AI ERA

AI systems are still systems

Access	Who can change prompts, models and training data?
Change	Is every model or prompt update approved, tested and versioned?
Operations	Are outputs monitored, and is there a fallback when the model fails?

ISO/IEC 42001 extends this thinking into a management system for AI.

FOR FRESHERS AND CAREER CHANGERS

ITGC as a way into cybersecurity

Why it works as an entry point

- Teaches how real systems are run, not only how they are attacked
- Valued wherever systems handle money, data or regulation
- Leads to risk, GRC, security architecture and audit leadership

How to start

- Learn the basics: access, change, backup and logging
- Practise: read an audit report and map findings to the four domains
- Certify when ready: CISA or ISO/IEC 27001 Lead Auditor

YOUR TURN · ANSWER IN THE CHAT

How would you have stopped each one?

Knight Capital, 2012
1 of 8 computers missed; nobody double-checked

Equifax, 2017
Security warning ignored for months

TSB Bank, 2018
Rushed to a deadline, testing cut back

CrowdStrike, 2024
Hidden fault slipped past testing

Type your fix for each one in the chat. Use what you learned today.

THE SOLUTIONS

Simple controls would have helped

Knight Capital

CHANGE

1 of 8 missed, nobody double-checked → **Written steps, and a second person checks every computer**

Equifax

CHANGE

Security warning ignored → **Fix known flaws fast, then check it is done**

TSB Bank

CHANGE + OPERATIONS

Rushed, testing cut back → **Test fully, readiness before date, keep a backup plan**

CrowdStrike

CHANGE

Fault slipped past testing → **Test updates first, then roll out in small steps**

CrowdStrike's own report lists staged rollout among its fixes. The others are standard good practice.

TAKEAWAYS

Remember three things

1. Small basics ignored lead to big losses. ITGC are those basics.
2. Ask three questions: who can enter, who can change it, does it keep running?
3. A control only counts when you can show proof that it worked.

OPEN FLOOR

Questions?

Thank you, Security Sync community

Connect with me: Dr. Ponnaluru Sowjanya on LinkedIn

SCAN TO CONNECT IN LINKEDIN

